

Cultivo Espacial — Informe estratégico de empresa

Fecha: 2026-06-14 · **Autor:** Claude (en rol combinado: ingeniería, CTO, VP de producto y mirada de CEO)

Para: Germán (fundador) · **Naturaleza:** documento de dirección, no técnico

*Este informe no mira la app: mira la **empresa**. Parte de un supuesto que vos ya tenés claro —*

esto es el comienzo de una compañía que va a lanzar varios productos relacionados, no un proyecto único.

Soy honesto a propósito: un informe que solo elogia no sirve para fundar nada serio.

0. Resumen ejecutivo (léelo aunque no leas el resto)

Tenés un **producto sorprendentemente completo para una sola persona**: cubre el ciclo entero (semilla → dispensación), 11 roles, web + mobile, contabilidad, compliance REPROCANN. Eso es un activo real y poco común.

Pero como **empresa**, hoy estás en estado *"producto avanzado, compañía inexistente"*. Las tres cosas que te separan de poder cobrarle a un club con tranquilidad no son features — son:

- **Postura de datos y seguridad** apta para datos médicos (hoy hay riesgos estructurales).
- **Continuidad del negocio**: si te pasa algo a vos, la empresa muere (bus factor = 1) y no hay backups/monitoreo formales.
- **Monetización real**: los planes existen pero el cobro es manual; no hay facturación, ni términos, ni contratos.

Ninguna es cara de arreglar ahora. Todas son carísimas de arreglar después de tener 50 clubes y un incidente. Este es el momento.

Veredicto: seguí construyendo, pero **en paralelo armá los cimientos de compañía**. El orden correcto es: legal/compliance → seguridad/continuidad → monetización → escala. No al revés.

1. La empresa vs. el producto

Estás pensando bien al separar "Cultivo Espacial" (empresa) de "Club Cultivo" (producto #1). Eso cambia decisiones desde hoy:

- **Marca y entidad madre:** Cultivo Espacial debería ser la sociedad; los productos (Club Cultivo, y los futuros) son líneas. Esto define cómo registrás la marca, cómo facturás y cómo repartís infra.
- **Infra compartida:** autenticación, facturación, panel de super-admin, identidad visual y storage deberían diseñarse como **servicios de plataforma**, no atados a Club Cultivo. Hoy están acoplados al producto. No hay que resolverlo ya, pero cada decisión nueva debería preguntarse "¿esto es de Club Cultivo o de Cultivo Espacial?".
- **Aprendizaje reutilizable:** multi-tenancy, compliance de datos sensibles, cobros SaaS — todo lo que resuelvas acá lo vas a reusar en los próximos productos. Documentarlo bien es construir capital de la empresa, no del proyecto.

2. Modelo de negocio y monetización

Lo que ya tenés

Planes definidos y con límites reales aplicados en código (`PlanEnforcer`):

Plan	Sedes	Lotes	Plantas	Pacientes	Usuarios
Semilla	1	2	50	30	3
Brote	2	6	150	100	8
Cosecha	3	∞	∞	250	20
Federación	∞	∞	∞	∞	∞

Buena base. Ahora la realidad de negocio:

Lo que falta para monetizar de verdad

- **No hay cobro automatizado.** Hoy el plan lo asigna a mano el super-admin (`cambiar_plan`). Eso no escala más allá de un puñado de clubes y depende de que vos cobres y actualices manual. **Necesitás una pasarela de suscripciones.** En Argentina: **Mercado Pago Suscripciones** (lo que los clubes ya entienden y usan) y/o Stripe si apuntás a cobrar en USD. El `plan_activo_hasta` y `plan_trial` ya existen — falta el webhook que los actualice automáticamente cuando entra/falla un pago.
- **No hay onboarding self-service.** Para escalar a 1000 clubes no podés crear cada club a mano. El camino "alta → trial → pago → activación" tiene que ser automático.
- **Definición de precios.** Los nombres de planes existen, los precios no están en ningún lado. Decisión de negocio pendiente: ¿precio en ARS (inflación → ajustes frecuentes) o anclado a USD/dólar MEP? ¿mensual vs anual con descuento? El cannabis-club argentino es sensible al precio; el trial generoso + plan Semilla barato como gancho suele funcionar.

El verdadero activo (tu visión de datos)

La monetización obvia es la suscripción. La **monetización grande** es lo que vos ya viste: **datos agregados del sector** (benchmarking, modelos de rendimiento por cepa, predicción). Eso es un segundo producto y una segunda fuente de ingresos — pero **legal y éticamente exige consentimiento explícito y anonimización real** (ver sección 3). No se improvisa; se diseña desde el principio con el opt-in que ya tenés (`benchmark_opt_in`).

3. Legal, regulatorio y compliance (tu mayor riesgo, y el menos técnico)

Sos analista de sistemas, así que esto es justo lo que "no es tu área" — y es lo que más puede hundir o blindar la empresa. Te lo ordeno por criticidad.

3.1 Datos personales sensibles (CRÍTICO)

Estás manejando **datos de salud**: patologías, indicaciones médicas, notas clínicas, REPROCANN. En Argentina eso cae bajo la **Ley 25.326 de Protección de Datos Personales** (habeas data), y los datos de salud son categoría "sensible" con protección reforzada. Implicancias concretas:

- Necesitás **consentimiento informado** del paciente para tratar sus datos.
- Los clubes son responsables del dato y vos sos el **encargado de tratamiento** → hace falta un **contrato de tratamiento de datos (DPA)** entre Cultivo Espacial y cada club.
- Registro de bases de datos ante la **AAIP** (Agencia de Acceso a la Información Pública).
- Derechos del titular: acceso, rectificación, supresión. Hoy la app no tiene un flujo formal de "borrame mis datos".

Esto no es opcional y no es técnico-primero: es legal-primero. Recomendación fuerte: **consultar un abogado especializado en protección de datos + cannabis** antes de cobrarle al primer club. Es la inversión de mayor retorno que podés hacer ahora.

3.2 Regulación cannabis

El marco (REPROCANN, ARICCAME/ANMAT) cambia y es político. La app ya tiene compliance incorporado (ventaja competitiva real), pero:

- Tu producto **facilita** la operación de clubes — definí en los términos que la responsabilidad del cumplimiento legal del cultivo/dispensación es del **club**, no tuya. Sos la herramienta, no el operador.
- Un cambio regulatorio puede romper supuestos del producto de un día para el otro. Conviene tener una línea con alguien que siga la normativa.

3.3 Estructura societaria

- **Constituir la sociedad** (SAS es lo ágil y barato en Argentina para empezar). Hoy, si facturás, ¿a nombre de quién? Esto bloquea cobrar formalmente.
- **Registrar la marca** "Cultivo Espacial" (y "Club Cultivo") en el INPI.
- **Acuerdo de socios** si en algún momento entra alguien más — definir participaciones, vesting, qué pasa si alguien se va. Mejor antes de necesitarlo.

3.4 Documentos de cara al cliente (faltan todos)

- **Términos y Condiciones** del servicio.
- **Política de Privacidad** (obligatoria por ley con datos personales).
- **DPA / contrato** con cada club.
- **SLA** (qué uptime prometés; ver sección 5).

4. Seguridad de datos (estado real y brechas)

Esto sí es mi terreno, y te lo digo sin maquillar porque con datos médicos es donde un incidente te termina la empresa.

Lo que está bien

- Autenticación con JWT en cookie httpOnly (recién endurecida — el token ya no queda expuesto a JavaScript).
- `Active Record Encryption` configurado para credenciales de dispositivos.
- `rack-attack` (rate limiting) y CORS restrictivo presentes.
- Rol auditor de solo-lectura forzado a nivel estructural; modo observador con expiración.

Las brechas que me preocupan (priorizadas)

- **Multi-tenancy por disciplina manual (ALTO).** El aislamiento entre clubes depende de que cada consulta filtre por `club_id` a mano. Un solo descuido expone datos de un club a otro — y con datos médicos eso es un incidente reportable, no un bug. **No hay red de seguridad a nivel base de datos** (Row-Level Security de PostgreSQL). Para una plataforma que vende aislamiento como propuesta de valor, esto hay que blindarlo antes de escalar. (Ya está en el informe de ingeniería como hallazgo A2.)
- **Autorización fragmentada (MEDIO-ALTO).** Hay tres mecanismos de permisos conviviendo y la matriz central es código muerto. Cada endpoint nuevo redefine permisos desde cero → superficie de error grande. (Hallazgo A1 del informe de ingeniería.)
- **Sin monitoreo de errores ni observabilidad (ALTO para negocio).** No hay Sentry/AppSignal ni equivalente. Hoy te enterás de que algo se rompió **cuando un club te escribe enojado**. Una empresa seria se entera antes que el cliente. Es barato de sumar y cambia tu capacidad de respuesta por completo.
- **Continuidad / backups (CRÍTICO).** No hay estrategia de backup verificada documentada. Render hace backups del Postgres administrado, pero **¿los probaste restaurando?** Un backup que nunca se restauró no es un backup. Con datos de pacientes, perder la base es perder la empresa.
- **Bus factor = 1 (CRÍTICO, no técnico).** Vos sos el único que entiende todo. Si te enfermás o querés tomarte un mes, la empresa se detiene. No se resuelve con código: se resuelve documentando y, eventualmente, sumando una persona.

Plan de incidentes

No existe. Mínimo viable: definir qué hacés si (a) se filtra data, (b) se cae el servicio, (c) se corrompe la base. Quién decide, a quién avisás (clubes, AAIP si hay filtración de datos personales), en cuánto tiempo.

5. Infraestructura y DevOps

Estado actual

- **Hosting:** Render.com (backend Dockerizado + Postgres administrado + Redis). Una instancia.
- **Storage:** migrando a object storage (R2) — en proceso.
- **Jobs:** Sidekiq + cron (vencimientos REPROCANN, alertas, informes). Bien.
- **Sin CI/CD:** no hay pipeline automático (`.github/workflows` ausente). Los tests existen (588 backend) pero **nadie garantiza que se corran antes de cada deploy** salvo tu disciplina.

Lo que una startup sería necesita (en orden)

- **CI/CD** (GitHub Actions): que cada push corra los tests y bloquee el deploy si fallan. Hoy dependés de acordarte de correr rspec. Barato, alto impacto.
- **Separación staging / producción** real, con datos de prueba en staging. (Ya tenés staging en Render — formalizarlo.)
- **Monitoreo + alertas** (errores con Sentry, uptime con un pinger, métricas de performance).
- **Backups verificados** con prueba de restauración periódica.
- **Gestión de secretos** sería (ya usás credentials de Rails + `RAILS_MASTER_KEY` ; falta documentar quién tiene acceso y rotación).
- **Escala horizontal** (cuando llegue): hoy una instancia. A 1000 clubes vas a necesitar varias + balanceo, y ahí el multi-tenancy manual y el storage local te explotan — por eso R2 y RLS importan antes, no después.

Costo mental

No necesitás nada de "nivel Google" ahora. Necesitás lo mínimo que evita los tres desastres: perder datos, no

enterarte de caídas, y desplegar algo roto. Eso es CI + monitoreo + backups probados. Es un fin de semana de trabajo, no un trimestre.

6. Organización y equipo

La verdad incómoda

Una empresa de software seria no la sostiene una persona indefinidamente. Hoy combinás, vos solo, los roles de: CEO, CTO, desarrollador full-stack, diseñador, soporte, ventas y compliance. Funciona para llegar hasta acá; **no funciona para escalar ni para que la empresa valga sin vos.**

Qué tendría que cubrir una versión seria de Cultivo Espacial (no significa contratar ya — significa saber qué falta)

Rol	Qué hace	Quién hoy	Prioridad de delegar
CEO	Visión, fondeo, decisiones, alianzas	Germán	— (es tuyo)
CTO / Lead Eng	Arquitectura, seguridad, decisiones técnicas	Germán	media (sos vos, pero documentá)
Dev(s)	Construir features	Germán	alta (primer hire natural)
Compliance / Legal	Datos, cannabis, contratos	nadie	CRÍTICA (asesor externo ya)
Soporte al cliente	Atender clubes	Germán	alta cuando haya >10 clubes
Ventas / Growth	Conseguir clubes	Germán	media
Contable/Finanzas	Facturación, impuestos de la empresa	nadie	alta al empezar a cobrar

Lo que vos (analista de sistemas) deberías hacer ahora

- **Lo que NO es tu área, delegalo a asesores** desde ya: legal/datos y contable. No intentes aprender derecho de datos; comprá esas horas.
- **Lo que SÍ es tu fuerte** (entender el dominio, el producto, la operación de los clubes): es exactamente la ventaja de un fundador analista — conocés el problema. Esa es tu cancha.
- **Documentá todo** para bajar el bus factor: es lo que convierte "lo que Germán sabe" en "lo que la empresa sabe".

7. Registro de riesgos (priorizado)

#	Riesgo	Impacto	Probabilidad	Mitigación
R1	Filtración de datos médicos entre clubes (tenancy manual)	Catastrófico	Media	RLS en Postgres + tests de aislamiento
R2	Sin marco legal de datos (Ley 25.326) al cobrar	Catastrófico	Alta si no se actúa	Abogado de datos + privacidad/DPA/T&C
R3	Pérdida de base de datos sin backup probado	Catastrófico	Baja	Backups verificados con restauración
R4	Bus factor = 1	Alto	Media	Documentación + primer hire
R5	No enterarse de fallas (sin monitoreo)	Alto	Alta	Sentry + uptime + alertas
R6	Cobro manual no escala	Alto	Alta (al crecer)	Pasarela de suscripciones + self-service
R7	Cambio regulatorio cannabis	Alto	Media	Términos que delimitan responsabilidad + seguimiento normativo
R8	Deuda técnica (autorización fragmentada, lógica en controllers)	Medio	Cierta	Refactors del informe de ingeniería

8. Hoja de ruta como empresa (no como producto)

Fase 1 — "Vendible con tranquilidad" (próximos pasos):

- Constituir SAS + registrar marca.
- Asesor legal de datos → T&C, Privacidad, DPA, registro AAIP.
- Storage en R2 (en curso) + backups probados + monitoreo de errores + CI.

- Blindar multi-tenancy (RLS).

Fase 2 — "Cobrible a escala":

- Pasarela de suscripciones (Mercado Pago) + onboarding self-service + facturación.
- Definir precios.
- Soporte mínimo estructurado (canal, SLA básico).

Fase 3 — "Escalable":

- Escala horizontal, CDN, observabilidad madura.
- Unificar autorización, pagar deuda técnica.
- Primer hire técnico.

Fase 4 — "Plataforma / holding":

- Extraer servicios de plataforma (auth, billing, identidad) reutilizables.
- Producto de datos sectoriales (con consentimiento + anonimización).
- Segundo producto sobre la misma base de empresa.

9. Mi recomendación de CEO en una frase

Frená el impulso de sumar features y dedicá las próximas semanas a convertir "una app que funciona" en "una empresa que puede cobrar sin riesgo": legal de datos, backups probados, monitoreo y multi-tenancy blindado. Eso vale más que cualquier módulo nuevo, porque es lo que te deja dormir tranquilo cuando tengas 100 clubes confiándote datos médicos.

Lo bueno: nada de esto es enorme. Es un orden de prioridades distinto, no más trabajo. Y la parte de producto —que es lo más difícil y donde la mayoría fracasa— ya la tenés mucho más avanzada que el 90% de las startups en esta etapa.